sel-firmware-threat-brief

SEL (Schweitzer Engineering Laboratories) Firmware Attack Surface & Detection Brief

Scope: 6 product lines / 14,255 unique hashes across 4 architecture classes (SEL-3355-2 industrial PC: 1,127; SEL-BaRT backup-recovery: 12,117; SEL Compass setup tool: 969; SEL-3300/3355 non-2: 16; Virtual Port Service 5828: 22). Findings combine CVE/PSIRT research with direct examination of the extracted Windows-side firmware and engineering-tool binaries (services, default configs, embedded resources). The relay (SEL-300/400/700) and RTAC (SEL-3530/3555) firmware is NOT in this extraction — those rows are research-only and explicitly marked.

Purdue layer mapping: Industrial PCs and engineering software (Groups A/B) live at **Purdue L3 (Site Operations)** as the substation EWS / HMI host tier; protective relays and RTAC comms processors (Groups C/D) sit at **Purdue L1 (Basic Controllers)**. See purdue-l3-site-operations-brief.md and purdue-l1-basic-controllers-brief.md for cross-vendor views.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. SEL Industrial PCs	L3 Site Operations (some deployments serve as L2 HMI panel)	SEL-3355-2, SEL-3355, SEL-3300	Windows 10 IoT LTSC / Win Server, ruggedized substation HMI/SCADA host, runs SEL acSELerator + RTU clients	1,143 hashes
B. SEL engineering software	L3 Site Operations	acSELerator QuickSet, SEL-BaRT, SEL Compass, Virtual Port Service 5828	Windows .NET / native, serial-over-TCP virtualization, relay config & firmware-push tooling	13,130 hashes
C. Protective relays (research only)	L1 Basic Controllers	SEL-300/351/387/400/421/451/487/700/751 series	Bare-metal embedded (proprietary RTOS), Fast Message / SEL ASCII / IEC 61850 GOOSE+MMS / DNP3	not extracted
D. Communications processors (research only)	L1 Basic Controllers (RTAC); L3.5 IT/OT Boundary (SEL-2730M managed switch)	SEL-3530 / SEL-3555 RTAC, SEL-2730M switch	Embedded Linux (RTAC OS), serves IEC 61850 / DNP3 / Modbus / IEC 60870-5-104 concentration	not extracted

Group A — SEL Industrial PCs (3355/3300 substation HMI hosts) — Purdue L3 (Site Operations); some deployments serve as L2 HMI panel

Direct attack surface (verified via PE imports and embedded `.inf`/service configs in the extracted 3355-2 catalog):

```
SMB · RDP · WinRM · SEL-5045 ICS Studio · acSELerator runtime · SEL Virtual-Port-Service (TCP s
```

The 3355-2 ships as a ruggedized Windows IoT box. Embedded driver packages in the extracted hashes include the SEL serial-port virtualization stack (Virtual-Port-Service 5828) and acSELerator helper services — both run as `LocalSystem` and listen on configurable TCP ports for serial-tunneling. Default Windows posture (SMB enabled, RDP often enabled for substation remote-ops) carries.

Confirmed advisories / CVEs:

Advisory	Product	Vector	Status on the firmware you have
CISA ICSA-23-131-08	SEL-5030 QuickSet, SEL-5033 RTAC, SEL-5045 ICS Studio	Bundled advisory covering CWE-276 insecure default permissions, CWE-22 path traversal, and CWE-269 improper privilege management in the acSELerator product family	acSELerator binaries present in BaRT catalog — verify versions against the advisory's fixed-build table
SEL Security Advisories index	acSELerator QuickSet (SEL-5030)	XML external entity (XXE) handling on relay project (`.aclx`) import → local file disclosure / SSRF; addressed in vendor-published 2023 advisory bundle	Triage operator workstations that open relay configs
CISA ICSA-23-194-02	SEL Real-Time Automation Controller (RTAC) family	Multiple weaknesses in RTAC firmware and management interfaces	Co-installed RTAC-management binaries staged via Compass

Top attack vector (MITRE ATT&CK ICS): T0817 Drive-by Compromise of the engineering workstation followed by T0843 Program Download — once acSELerator is compromised, the operator's own session pushes tampered logic to downstream relays. INL's CRASHOVERRIDE post-mortem and Dragos's PIPEDREAM analysis both flag engineering workstations as the highest-value foothold in substation environments.

Group B — SEL engineering software (acSELerator / BaRT / Compass / VPS) — Purdue L3 (Site Operations)

Direct attack surface (from the 12,117 BaRT hashes + 969 Compass hashes + 22 VPS binaries):

SEL-BaRT is the relay backup/restore tool — it speaks SEL Fast Message and SEL ASCII over serial or TCP-virtualized serial to read/write **relay settings groups and firmware**. SEL Compass is the launcher/updater that authenticates to SEL's update servers and stages firmware payloads to disk. Virtual Port Service 5828 exposes a TCP listener (default 23xxx range) that bridges to local COM ports — any code that can talk to that listener can drive an attached relay as if it had physical serial access.

Confirmed advisories / CVEs:

Advisory	Product	Vector	Status on the firmware you have
CISA ICSA-23-131-08	acSELerator QuickSet (SEL-5030)	DLL search-order / writable-install-path class enabling local privilege escalation to SYSTEM via service restart	Audit DLLs in the BaRT/Compass install trees you extracted; flag any unsigned or non-SEL DLL
SEL Security Advisories index	SEL-5037 Grid Configurator	Cleartext / weakly-protected storage of project credentials in configuration DB	Grid Configurator not in this dataset, but commonly co-installed
CISA ICSA-23-131-08	acSELerator Team (SEL-5045) ICS Studio	Improper authentication / authorization on local IPC + management endpoints	Co-installed with ICS Studio binaries in this catalog
SEL Security Advisories index	acSELerator Architect (SEL-5032)	Authorization / project-import handling weaknesses (2024 vendor advisory cycle)	Architect commonly bundled in Compass-managed installs

Top attack vector: T0822 External Remote Services → T0857 System Firmware. The BaRT-style backup/restore flow is the canonical relay-firmware-tamper path; ICEFALL-class trust-bus weaknesses in OT engineering tools were the centerpiece of Forescout's 2022 disclosure series.

Group C — Protective relays (research only, firmware NOT extracted) — Purdue L1 (Basic Controllers)

SEL relays (300/351/387/400/421/451/487/700/751 series) are bare-metal embedded with proprietary code-signed firmware. They expose:

- **SEL Fast Message** and **SEL ASCII** on serial / serial-over-TCP — the native control plane (read settings, write settings, trip/close breakers, reset targets).
- **IEC 61850 MMS** (TCP/102) and **GOOSE** (Ethertype 0x88B8) on Ethernet-enabled variants.
- **DNP3** (TCP/20000) and **IEC 60870-5-104** (TCP/2404) where licensed.

Attack vectors (no extraction-confirmed CVEs — assume CVE history is thin due to closed source):

- **GOOSE injection** — INL/DOE red-team work (2019-2023) repeatedly demonstrated unauthenticated GOOSE on substation LANs causes unintended breaker operation. Mitigation is GOOSE MAC (IEC 62351-6), rarely deployed.
- **Settings-group switch via Fast Message** — operator-equivalent commands; if attacker reaches the relay's serial or virtualized-serial bridge they can swap protection settings.
- **Manufacture-time / default level passwords** — SEL relays historically shipped with well-known default level-1/2/C passwords (`OTTER`, `TAIL`, `CLARKE`); INL pen-tests still find these unchanged in the field.

Top vector: T0855 Unauthorized Command Message via GOOSE or Fast Message from a compromised engineering workstation. CRASHOVERRIDE used precisely this pattern against Ukrenergo (different relay vendor, identical class of attack).

Group D — RTAC communications processors (research only) — Purdue L1 (RTAC) + L3.5 (SEL-2730M managed switch)

SEL-3530 / SEL-3555 RTAC runs an embedded Linux ("RTAC OS"). It concentrates protocols (DNP3 master/slave, IEC 61850 client, Modbus, IEC 60870-5-104) and runs IEC 61131-3 logic. Public CVE coverage in this family is sparse; the CISA ICSA-23-194-02 RTAC advisory bundle is the public anchor. Attack-surface assumption: HTTPS web UI on TCP/443, SSH on TCP/22 (factory-disabled but operator-enabled in the field), DNP3 outstation, and the IEC 61850 client/server stack.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**Sysmon on SEL engineering workstations**	EventID 1 ProcessCreate where ParentImage= `AcSELeratorQuickSet.exe` / `BaRT.exe` / `Compass.exe` AND child not in SEL allow-list	acSELerator post-exploitation / firmware-push abuse	T0843 Program Download
2	Sysmon	EventID 7 ImageLoad on `AcSELerator*.exe` / `BaRT.exe` loading DLLs from user-writable paths	DLL search-order hijack LPE class	T1574.001
3	Sysmon	EventID 11 FileCreate of `*.aclx` / `*.RDB` / `*.crd` from non-engineer accounts	Tampered relay-settings project staging	T0873 Project File Infection
4	**Network IDS (Zeek/Suricata)**	TCP/102 MMS `write` services from non-engineering hosts	IEC 61850 settings tamper	T0836 Modify Parameter
5	Network IDS	GOOSE frames (Ethertype 0x88B8) sourced from non-relay MACs, or stNum jumps > expected	GOOSE spoofing precursor	T0855 Unauthorized Command Message
6	Network IDS	DNP3 function codes 5 (DirectOperate) / 6 (DirectOperateNoAck) crossing engineering→OT boundary	Breaker trip/close abuse	T0831 Manipulation of Control
7	Network IDS	Connections to **Virtual Port Service 5828** TCP listener from non-loopback / non-engineering IPs	Lateral relay access via serial tunnel	T0886 Remote Services
8	**SEL relay SER / Sequential Events Recorder** via syslog	Settings-group change, password-attempt failures, breaker operation outside scheduled windows	Live relay tamper detection	T0858 Change Operating Mode

Secondary:

- **Firewall:** any egress from substation engineering VLAN to non-RFC1918 (engineering workstations should never originate outbound to internet — SEL Compass updates can be staged via an internal mirror).
- **SEL relay audit logs:** every SEL-400/700-series relay has a built-in SER buffer and Audit log accessible via Fast Message `HIS` / `MET`. Pull on schedule and diff for unexpected setting-group changes, level-2/C password failures, and `RST TARGET` events.
- **Compass update channel:** monitor outbound TLS to `updates.selinc.com` / `compass.selinc.com` — only the Compass-host should originate these; any other host doing so is a staging artifact.

Power-anomaly signals (the OT-native detection):

- Unexpected breaker open/close events in relay SER buffer outside maintenance windows
- Setting-group switch (relay reports `SG=N` change) with no concurrent operator-ticket trail
- IEEE C37.118 synchrophasor stream gaps / quality-flag changes on PMU-capable relays — control-loop tamper precursor

---

Specific zero-day-ish concerns for your dataset

1. **acSELerator DLL-hijack / writable-install-path class (covered by ICSA-23-131-08 and the SEL 2023 advisory bundle) on a substation workstation is the operator-equivalent compromise.** The 1,127 SEL-3355-2 hashes plus 969 Compass hashes are exactly the engineering-workstation profile. Diff the DLL imports in your extracted catalog against SEL's signed-binary manifest; any unsigned or non-SEL DLL in the install tree is a planted hijack candidate.

2. **SEL-BaRT (12,117 hashes — the largest single product in the extraction) is the firmware-push tool.** Its trust relationship with downstream relays is unauthenticated at the Fast Message layer. Any compromise of BaRT.exe or its config DB = silent relay-firmware tamper across the substation. Treat BaRT-host binaries as crown-jewel and integrity-monitor them at file-hash level.

3. **Virtual Port Service 5828 (22 hashes) — small but high-blast-radius.** VPS exposes a local TCP listener that bridges to physical COM ports. Verify in the extracted binaries (a) what interface it binds to (loopback vs 0.0.0.0), (b) whether it enforces any auth, (c) what port range it uses by default. If it binds to 0.0.0.0 with no auth, it is a remote serial-console-equivalent on the management VLAN.

4. **Public CVE coverage against SEL relay firmware itself is thin**, despite INL/DOE red-team reports describing exploitable conditions. Closed-source + light public scrutiny ≠ no bugs. Plan extraction of SEL-3530/3555 RTAC firmware next — it is the embedded-Linux concentrator and the easiest pivot into the relay LAN.

Sources

- CISA ICS Advisory ICSA-23-131-08 — SEL acSELerator multiple products
- CISA ICS Advisory ICSA-23-194-02 — SEL Real-Time Automation Controller (RTAC)
- SEL Security Advisories index

- Forescout — OT:ICEFALL research (engineering-tool trust-bus class)
- Dragos — PIPEDREAM/CHERNOVITE analysis (engineering-workstation pivot)
- INL — Cyber-Informed Engineering and substation red-team findings
- MITRE ATT&CK for ICS — Initial Access (TA0108)
- MITRE ATT&CK for ICS — Impair Process Control (TA0106)
- MITRE ATT&CK for ICS — T0857 System Firmware
- MITRE ATT&CK for ICS — T0855 Unauthorized Command Message
- MITRE ATT&CK for ICS — T0836 Modify Parameter
- MITRE ATT&CK for ICS — T0843 Program Download
- CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection (2024)
- Claroty Team82 — research blog (ICS engineering-tool advisories)

VT behavioural differential — SEL corpus (2026-10-27)

Generated by `tools/Invoke-VendorDifferential.ps1` against the SEL known-good baseline (NSRL + local, platform-matched) and the VT malicious target set (7913 targets). Each behaviour is scored by how **rare** it is in this vendor's own known-good software: `rarity 100` = the baseline *never* exhibits it; a lower score = the baseline does, so it is scored down as benign-common.

> **Read this correctly.** The sparse OT baseline means the rarity-100 list is dominated by *generic* malicious behaviour, not SEL-specific indicators — any comparable malware trips most of it. The genuinely SEL-specific product of this differential is the **suppression list** at the end: behaviours this vendor's real software performs, which must **not** be alerted on when monitoring a host that runs it. Use the MITRE table as the TTP-tier hunting frame; use the suppression list to cut false positives.

Category	Behaviours observed	Discriminating (rarity 100)	Benign-common (suppressed)
MITRE ATT&CK	852	852	0
Windows API	210	31	179
Process/cmdline	6164	6164	0
Registry	43285	43285	0
Mutex	1898	1898	0
YARA	1460	1454	6
Sigma	588	571	17
Certificate	4	3	1
Tags	263	196	67
ELF (native imports)	1186	700	486

Top discriminating MITRE ATT&CK techniques

Techniques present in the malicious corpus and **absent from the SEL known-good baseline**, ranked by how many malicious samples exhibit each.

Technique	Malicious samples	Last seen
T1082: Reads software policies	404	2026-02-04
T1082: Queries the volume information (name, serial number etc) of a device	350	2026-02-04
T1071: Adversaries may communicate using application layer protocols to avoid detection/network filtering by blending in with existing traffic.	348	2026-02-04
T1083: Reads ini files	321	2026-02-04
T1497: May sleep (evasive loops) to hinder dynamic analysis	319	2026-02-04
T1036: Creates files inside the user directory	289	2026-02-04
T1010: Sample monitors Window changes (e.g. starting applications), analyze the sample with the simulation cookbook	266	2026-02-04
T1518.001: May try to detect the virtual machine to hinder analysis (VM artifact strings found in memory)	266	2026-02-04
T1574.002: Tries to load missing DLLs	266	2026-02-04
T1497: Contains long sleeps (>= 3 min)	263	2026-02-04
T1082: An adversary may attempt to get detailed information about the operating system and hardware, including version, patches, hotfixes, service packs, and architecture.	247	2026-02-04
T1497: Contains medium sleeps (>= 30s)	238	2026-02-04

Highest-prevalence behavioural discriminators (top 5 per type)

Behaviour	Type	Malicious samples
HKEY_LOCAL_MACHINE\Software\Microsoft\OLE	Registry	421
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\SessionIn	Registry	316
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Internet Settings\	Registry	314
HKEY_CURRENT_USER\software	Registry	307
HKEY_LOCAL_MACHINE\Software\Microsoft\Fusion	Registry	290
C:\Windows\system32\services.exe	Process/cmdline	299
C:\Windows\System32\conhost.exe C:\Windows\system32\conhost.exe 0xffffffff -Fo	Process/cmdline	287
C:\Windows\Explorer.EXE	Process/cmdline	216
C:\Windows\System32\svchost.exe -k NetworkService -p	Process/cmdline	130
C:\Windows\system32\svchost.exe -k UnistackSvcGroup	Process/cmdline	130
kernel32.dll!FindAtomW	Windows API	7
kernel32.dll!CopyFileExA	Windows API	6

Behaviour	Type	Malicious samples
kernel32.dll!GetPriorityClass	Windows API	6
kernel32.dll!AddAtomW	Windows API	5
kernel32.dll!DeleteAtom	Windows API	5
Local\ZonesLockedCacheCounterMutex	Mutex	229
Local\ZonesCacheCounterMutex	Mutex	227
Global\MTX_MSO_AdHoc1_S-1-5-21-1547548985-192504236-2982455695-500	Mutex	146
Global\MTX_MSO_Formal1_S-1-5-21-1547548985-192504236-2982455695-500	Mutex	146
\Sessions\1\BaseNamedObjects\Local\ZonesCacheCounterMutex	Mutex	132

Device-firmware plane — top ELF native-import discriminators

The SEL baseline also covers embedded-Linux device firmware; these ELF imports appear in the malicious ELF corpus but not in SEL firmware.

Symbol / import	Malicious samples
ELF!__deregister_frame_info	135
ELF!__register_frame_info	132
ELF!__pthread_initialize_minimal	112
ELF!daemon	69
ELF!htons	59
ELF!__lxstat64	49
ELF!atoi	48
ELF!gethostname	42

Benign-common behaviours — suppress for this vendor (do NOT alert)

These appear in the SEL known-good baseline, so the differential scores them down and they should not drive alerts on a host running genuine SEL software. `base%` = share of the baseline exhibiting the behaviour. (733 suppressed in total; top 15 shown.)

Behaviour	Type	base%	rarity
No Sig	Certificate	93.0241%	7
known-distributor	Tags	56.7532%	43
legit	Tags	40.2597%	60
text	Tags	22.5417%	77
xml	Tags	19.3506%	81
64bits	Tags	11.9481%	88
elf	Tags	10.0557%	90
python	Tags	8.2931%	92

Behaviour	Type	base%	rarity
shared-lib	Tags	8.0334%	92
ELF!_ITM_deregisterTMCloneTable	ELF (native imports)	6.9202%	93
ELF!__stack_chk_fail	ELF (native imports)	6.8089%	93
ELF!**gmon_start**	ELF (native imports)	6.6234%	93
signed	Tags	5.4917%	95
via-tor	Tags	5.4545%	95
ELF!_ITM_registerTMCloneTable	ELF (native imports)	4.6382%	95